Разбор фишингового письма

Данный разбор сделан в исключительно образовательных целях

Используемые инструменты для разбора:

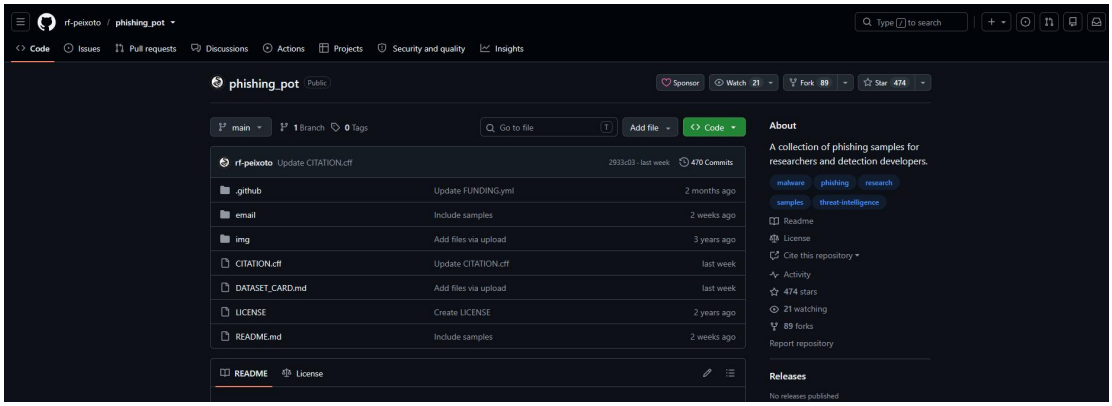
- Репозиторий на GitHub (rf-peixoto/phishing_pot), содержащий реальные фишинговые письма
- Бесплатные онлайн-инструмент (urlscan.io) для проверки ссылок внутри

Содержание файла:

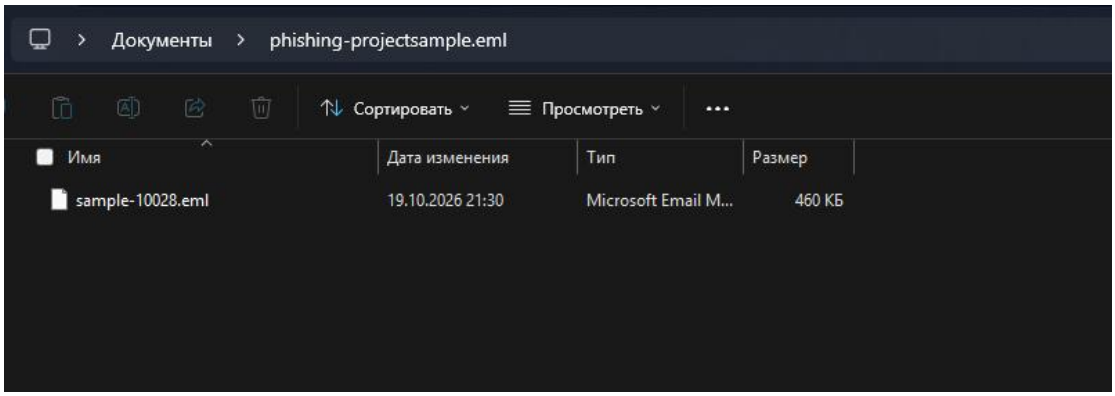
- Описание действий и анализ проверки
- Отчет фишингового письма по результатам проверки

Описание действий и анализ проверки:

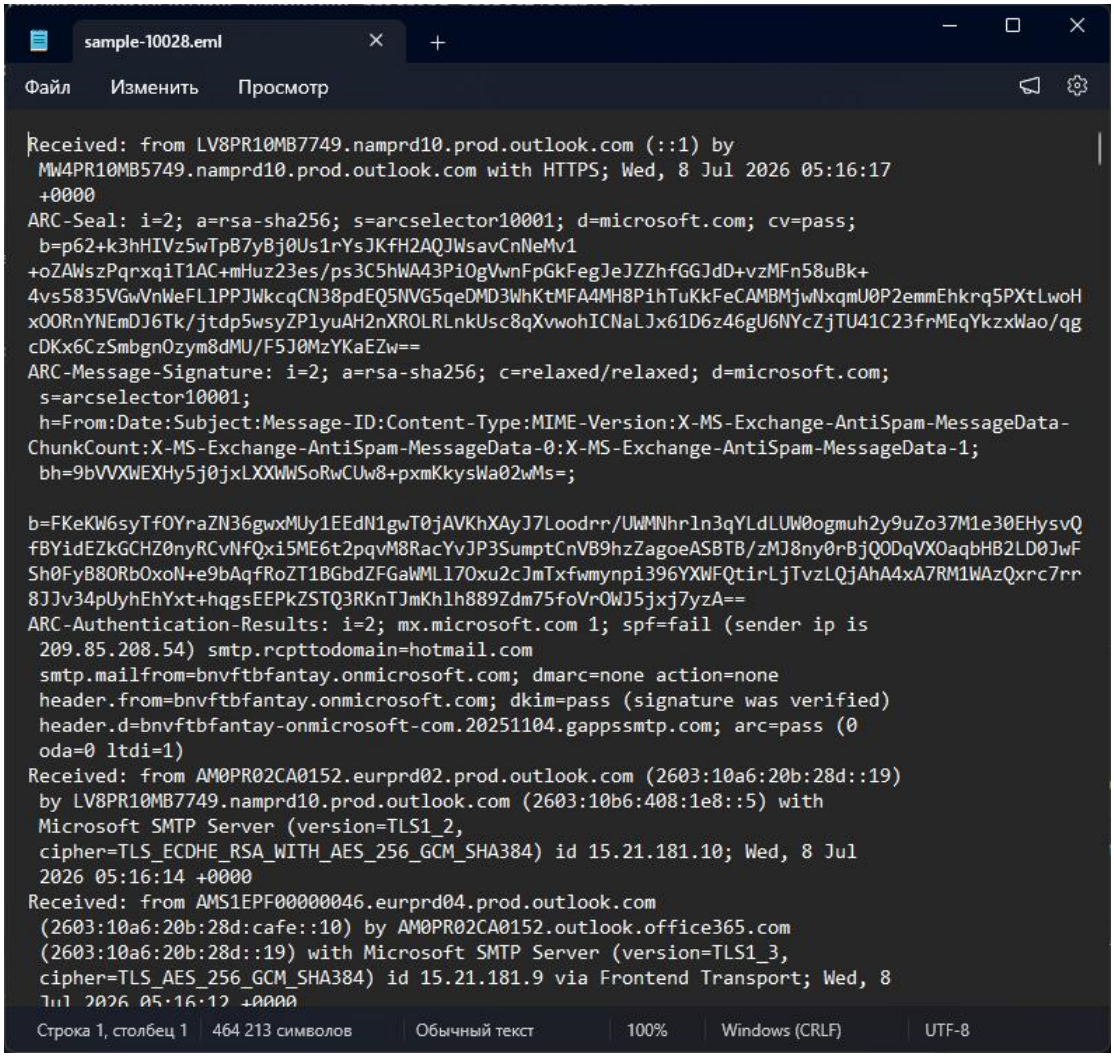
В репозитори на GitHub (rf-peixoto/phishing_pot) скачиваю вайл с расширением ‘.eml’из папки ‘email/’



Выбираю первый попавшейся файл и сохраняю его на ПК в отдельную папку



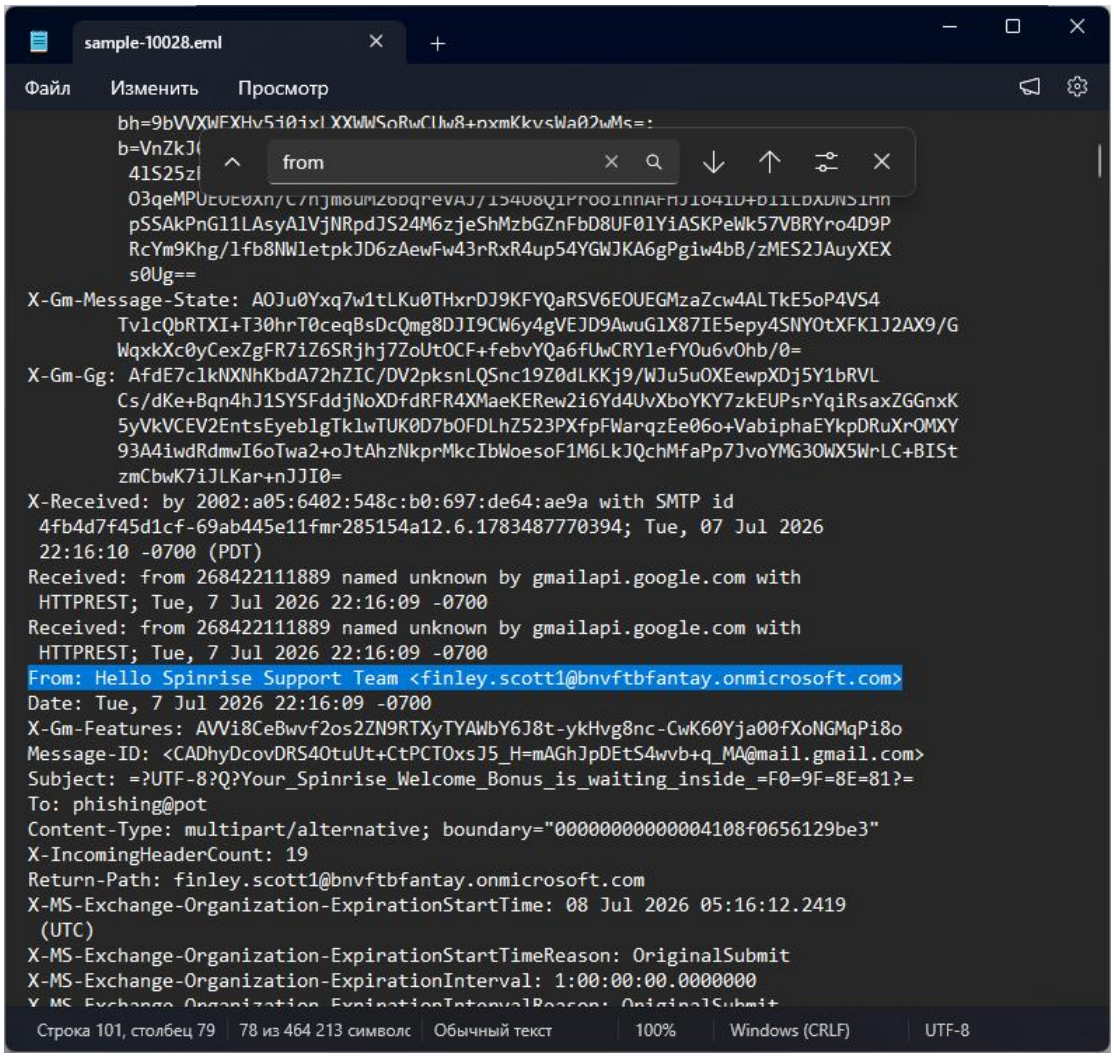
Открываю файл в Блокноте



Анализирую текст и заполняю таблицу с данными:

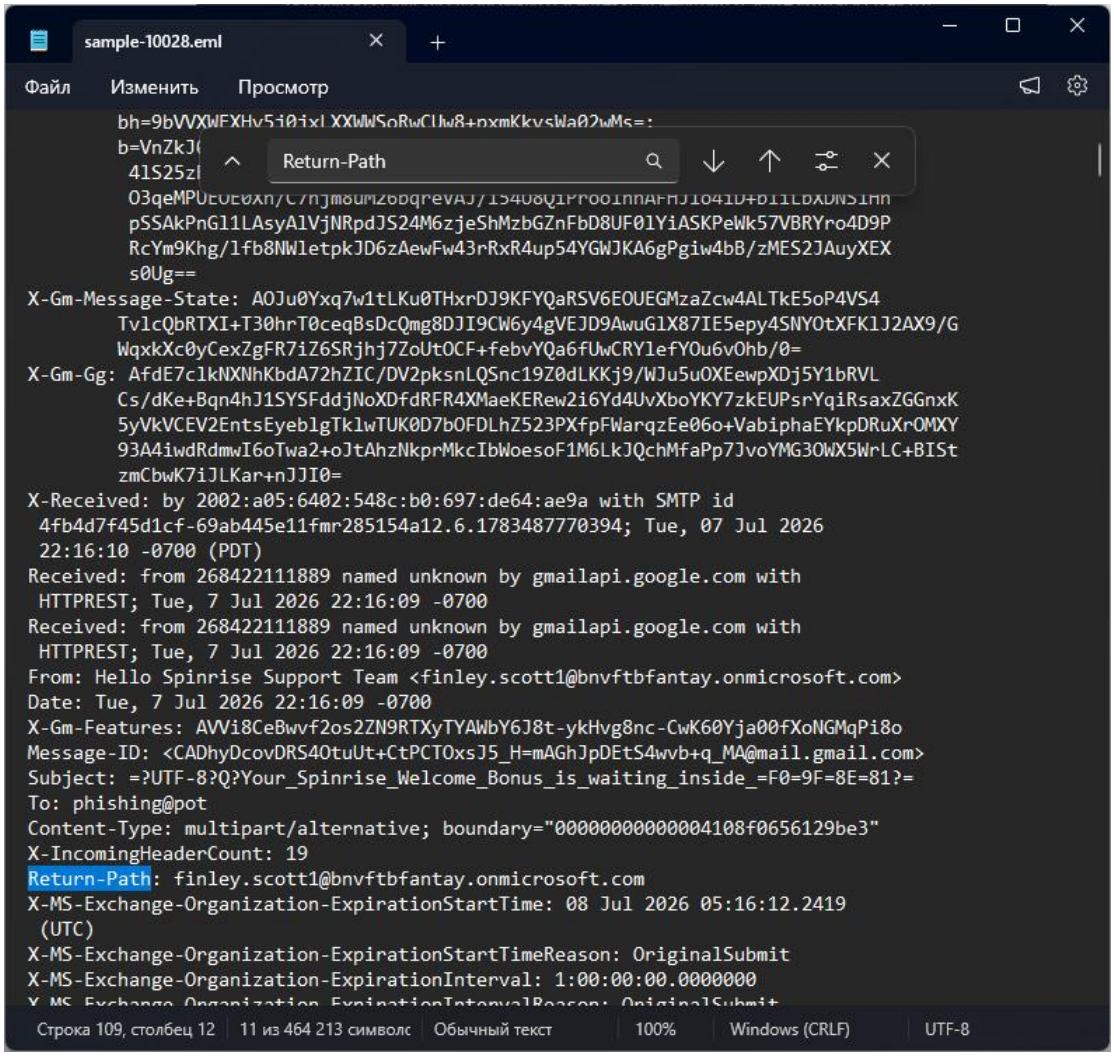
Поле	Что означает	Результат
From	Отображаемый отправитель	Hello Spinrise Support Team <finley.scott1@bnvftbfantay.onmicrosoft.com>
Return-Path	Куда письмо вернётся при ответе	finley.scott1@bnvftbfantay.onmicrosoft.com
Reply-To	Куда уйдет ответ при нажатии «Ответить»	Отсутствует
Authentication-Results	Результаты проверки SPF/DKIM/DMARC	spf=fail (sender IP is 209.85.208.54)
Received	Путь письма через серверы	Письмо доставлено через инфраструктуру Microsoft (Outlook). Время получения: Wed, 8 Jul 2026 05:16:17 +0000.

Пояснение к таблице:



Адрес отправителя: finley.scott1@bnvftbfantay.onmicrosoft.com

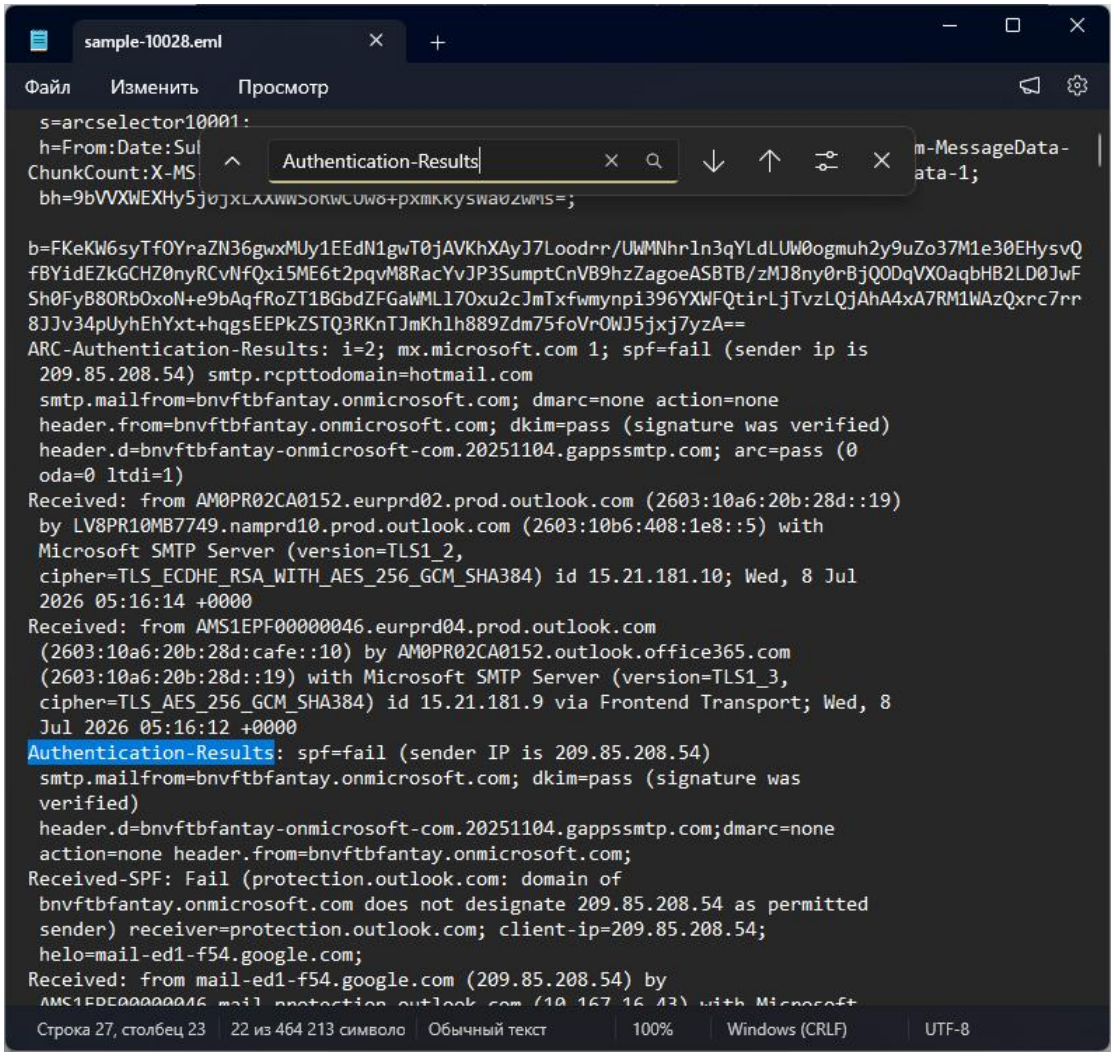
Поятнение: onmicrosoft.com — это технический домен, который Microsoft выдает организациям по умолчанию при регистрации в Office 365. Настоящие компании (особенно если они называют себя "Support Team") используют свои красивые домены (например, @spinrise.com). А набор букв bnvftbfantay выглядит как сгенерированный ботом при массовой регистрации.



Письмо вернётся к отправителю-злоумышленнику

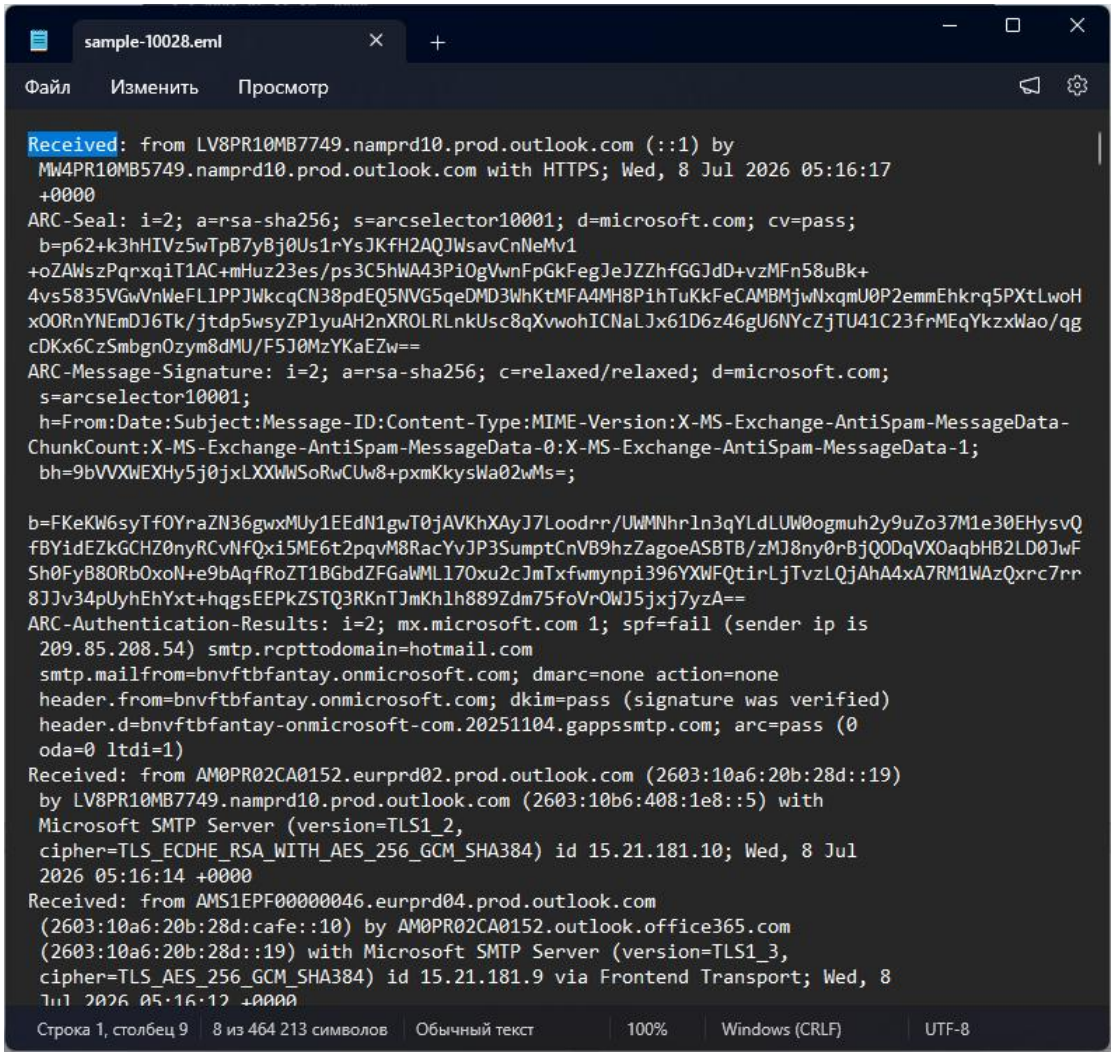
Выше есть строчка: «Received: from 268422111889 named unknown by gmailapi.google.com with HTTPREST; Tue, 7 Jul 2026 22:16:09 -0700»

Обращаю внимание на « with HTTPREST». Обычные письма отправляются по протоколу SMTP. А здесь использовался HTTPREST. Это означает, что письмо было отправлено не через обычный почтовый клиент, а программно, с использованием HTTP REST API Google, что характерно для автоматизированных ботнетов и массовых фишинговых рассылок.



spf=fail — проверка провалена. Злоумышленник использовал инфраструктуру Google для отправки писем, подделав адрес отправителя на домен Microsoft, поэтому проверка подлинности сервера-отправителя провалилась.

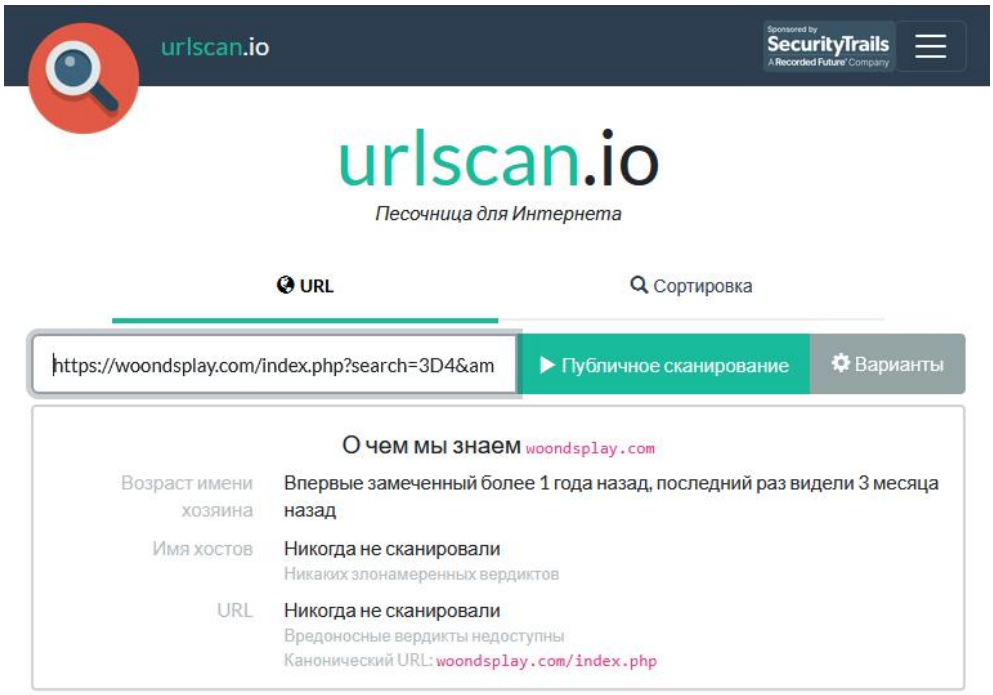
dmarc=none — владелец домена не настроил защиту.



Можно заметить, что даты отправления (From) и получения сервером (Received) технически совпадают. Письмо было отправлено 7 июля 2026 года в 22:16 (по часовому поясу -0700), что при переводе в UTC (всемирное координированное время) дает 8 июля 2026 года 05:16. Временные метки корректны и не являются признаком подделки.

Перехожу к этапу проверки ссылок через онлай-сервис

В блокноте ищу ссылки по поиску ‘http’ и вставляю ее в сервис urlscan.io



Вывод:

Анализ домена woondspiay.com:

При проверке домена в сервисе urlscan.io было выявлено, что домен не является популярным ресурсом и ранее не проходил сканирование (вредоносных вердиктов нет). При этом домен был зарегистрирован более года назад. Это характерно для так называемых «спящих» доменов, которые злоумышленники приобретают заранее, чтобы обойти фильтры почтовых сервисов и создать видимость легитимного сайта. URL (.../index.php) указывает на то, что это самописная страница-ловушка, а не полноценный корпоративный портал компании Spinrise.

Отчет фишингового письма по результатам проверки

Анализ фишингового письма (образец sample-10028.eml)

Аналитик: nastyaaa-inf-sec
Дата анализа: 19.10.2026
Источник образца: Публичный репозиторий GitHub rf-peixoto/phishing_pot (образец sample-10028.eml).

Образец электронного письма является фишинговым. Злоумышленники используют методы социальной инженерии и подделку адреса отправителя для того, чтобы заставить пользователя перейти на вредоносный сайт. Письмо содержит явные технические признаки компрометации (провал проверки SPF, автоматизированная отправка через Google API).

Анализ заголовков

При детальном изучении заголовков письма (.eml) были выявлены следующие аномалии:

Поле	Значение	Вывод аналитика
From	Hello Spinrise Support Team <finley.scott1@bnvftbfantay.onmicrosoft.com>	Злоумышленник маскируется под службу поддержки. Используется технический домен Microsoft (onmicrosoft.com) со случайным набором символов.
Return-Path	finley.scott1@bnvftbfantay.onmicrosoft.com	Совпадает с адресом отправителя.
Authentication-Results	spf=fail (sender IP is 209.85.208.54)	Проверка подлинности сервера отправителя провалена.
Received (IP)	mail-ed1-f54.google.com (209.85.208.54)	Письмо отправлено с инфраструктуры Google, которая не авторизована для домена onmicrosoft.com.
Received (метод)	with HTTPREST	Письмо отправлено программно (через API), а не человеком из обычного почтового клиента. Это признак массовой бот-рассылки.
Subject	Your Spinrise Welcome Bonus is waiting inside	Применяется метод социальной инженерии с использованием приманки (обещание бонуса) для побуждения пользователя к клику.

Анализ ссылок и инфраструктуры

Обнаруженный URL: https://woondspiay.com/index.php?search=... (ссылка содержит длинный набор уникальных параметров для отслеживания конкретной жертвы).

Анализ домена:

- Домен woondspiay.com не имеет отношения к заявленной компании Spinrise.
- Согласно данным сервиса urlscan.io (или Cloudflare Radar), домен не является популярным ресурсом и ранее не сканировался.
- Домен был зарегистрирован более года назад. Это характерно для «спящих» доменов, которые покупаются заранее для обхода антиспам-фильтров.

Анализ изображений: Для отрисовки кнопки используется бесплатный хостинг картинок (i.imgur.com), что также является признаком несерьезной инфраструктуры, не свойственной крупным компаниям.

Заключение и рекомендации

Письмо представляет собой классическую фишинговую атаку, направленную на кражу данных или вовлечение пользователя в мошенническую схему.

Признаки фишинга:

- Провал аутентификации SPF.
- Использование дефолтного домена Microsoft с автоматически сгенерированным именем.
- Автоматизированная отправка через Google API (HTTPREST).
- Аномальные даты в заголовках.
- Ссылка на подозрительный домен woondspiay.com.

Рекомендации по защите:

- Пользователям: Не переходить по ссылкам, не вводить личные данные. Пометить письмо как спам/фишинг.
- Службе безопасности (SOC): Заблокировать домен woondspiay.com и IP-адрес 209.85.208.54 на почтовом шлюзе. Настроить правила для фильтрации писем с проваленным SPF от доменов onmicrosoft.com.

Выполнила:
nastyaaa-inf-sec

Ссылка на GitHub:
https://github.com/nastyaaa-inf-sec